

ECOM EXPERTS

# Ecom connectclient

Manual de usuario, técnico y de desarrollo

---

ecom\_connectclient 1.0.0 · 08/09/2026

## Contenido

### 1. Para qué sirve

### 2. Instalación

### 3. Configúralo antes de usarlo

## General

## Acceso y seguridad

## Protección de datos

## Aviso al cliente

### 4. Cómo conectar

### 5. Mientras estás dentro

### 6. El registro de accesos

### 7. Preguntas frecuentes

#### 1. Qué hace

#### 2. Estructura de ficheros

#### 3. Base de datos

## PREFIX\_ecom\_ccl\_log — registro de accesos

## PREFIX\_ecom\_ccl\_ticket — tickets de un solo uso

### 4. Flujo completo

### 5. Hooks registrados

### 6. Configuración

### 7. Medidas de seguridad implementadas

### 8. Mantenimiento automático

### 9. Traducciones

### 10. Depuración

#### 1. Decisiones de diseño y por qué

### 1.1 Ticket de un solo uso, no escritura directa de la cookie

### 1.2 Primero el registro, después el ticket

### 1.3 Bloqueo por actionDispatcherBefore, no por hooks de objeto

### 1.4 Configuración global, no por tienda

### 1.5 Copia del nombre y del correo en el registro

### 1.6 Sin src/, sin Composer

2. Trampas ya pisadas (no repetirlas)

---

3. Cómo probar los caminos importantes

---

4. Extensiones razonables

---

5. Convenciones del proyecto que aplican aquí

---

1. Por qué esto es un tratamiento de datos personales

---

2. Base de licitud (artículo 6.1 del RGPD)

---

3. Principios del artículo 5 y su traducción en el módulo

---

4. Seguridad del tratamiento (artículo 32 del RGPD)

---

5. Transparencia (artículos 12 a 14)

---

6. Derechos del interesado (artículos 15 a 22)

---

7. Obligaciones que siguen siendo tuyas

---

8. Recomendaciones de configuración

---

9. Fuentes

---

## 1. Para qué sirve

---

Cuando un cliente llama diciendo «no me deja pagar», «no se me aplica el descuento» o «no veo mi pedido», lo más rápido es ver la tienda tal y como la ve él. Este módulo te deja abrir el front con su sesión, sin pedirle la contraseña y sin cambiársela.

Todo lo que hagas queda anotado: quién eres, a qué cuenta entraste, cuándo, desde qué dirección IP y con qué motivo. Es una funcionalidad de soporte, no una llave maestra.

---

## 2. Instalación

---

1. Sube el ZIP desde **Módulos** → **Gestor de módulos** → **Subir un módulo**.
2. Pulsa **Instalar**.
3. Entra en **Configurar**.

El módulo crea una entrada nueva en el menú **Clientes** → **Conectar como cliente**, que es el registro de accesos.

---

## 3. Configúralo antes de usarlo

---

En **Configurar** hay un único formulario con cuatro pestañas y un solo botón de guardar.

### General

- **Activar la funcionalidad.** Si la apagas no se puede abrir ninguna sesión nueva, pero el registro sigue disponible.
- **Página de destino:** dónde aterrizas al conectar (cuenta del cliente, historial de pedidos, inicio o carrito).
- **Mostrar el aviso visible:** la barra roja que se ve en el front durante la sesión. **Déjala activada.**
- **Registro de depuración:** solo si hay que diagnosticar un problema del módulo.

### Acceso y seguridad

- **Perfiles autorizados:** marca solo los que de verdad tengan que entrar. Por defecto, solo SuperAdmin.
- **Duración máxima de la sesión:** pasado ese tiempo se cierra sola. 15 o 30 minutos sobra.
- **Máximo de conexiones por empleado y hora:** evita que nadie recorra muchas cuentas seguidas.
- **Modo de solo lectura:** con él activado no se puede pedir, pagar ni cambiar nada. Es lo recomendable: la mayoría de incidencias se ven mirando.
- **No permitir nunca cambiar el correo ni la contraseña:** déjalo activado siempre.

## Protección de datos

- **Base de licitud:** por qué estás autorizado a entrar. Por defecto, ejecución del contrato. Si eliges «consentimiento», el módulo te pedirá anotar cómo lo dio el cliente y no te dejará conectar sin ello.
- **Exigir un motivo** y su longitud mínima.
- **Conservación del registro (meses):** cuánto tiempo se guardan los accesos antes de borrarse solos.
- **Responsable del tratamiento** y **contacto de protección de datos:** aparecen en el correo que recibe el cliente.
- **Cláusula para tu política de privacidad:** cópiala y pégala en tu política de privacidad. Es obligatorio informar de esto.

## Aviso al cliente

- **Avisar al cliente por correo en cada acceso.** Recomendado.
- **Copia interna a:** una dirección tuya que reciba copia de cada aviso, para supervisión.

Debajo del formulario tienes el panel **Información legal y cumplimiento del RGPD**, que explica qué obligaciones te corresponden a ti como titular de la tienda.

---

## 4. Cómo conectar

1. Ve a **Cientes** → **Cientes** y abre la ficha del cliente (el ojo, «Detalles»).
2. Baja hasta el panel **Conectar como cliente**.
3. Escribe el **motivo** con detalle. No sirve «prueba»: escribe qué incidencia estás mirando y, si la hay, el número de pedido.
4. Deja marcado **Solo lectura** salvo que necesites de verdad hacer algo en su nombre.
5. Marca la casilla de confirmación.
6. Pulsa **Abrir una sesión de soporte**. Se abre una pestaña nueva con el front y la sesión del cliente. **Tu sesión del back-office no se pierde.**

En el front verás una barra roja arriba con tu nombre, el modo (solo lectura o acceso completo) y el tiempo restante.

---

## 5. Mientras estás dentro

- Si el modo de solo lectura está activo y pulsas algo que modifique (añadir al carrito, finalizar la compra, cambiar una dirección), la acción se bloquea y aparece un aviso. Ese intento queda anotado; es normal y no es un error.
- El cambio de correo y de contraseña está bloqueado siempre.
- Cuando acabes, pulsa **Cerrar la sesión** en la barra roja. Si no lo haces, la sesión se cierra sola al cumplirse la duración máxima.
- **Cierra la pestaña al terminar.**

---

## 6. El registro de accesos

---

### **Clientes → Conectar como cliente.**

Es la lista de todos los accesos. Puedes filtrar por texto, por cliente, por empleado y por fechas, y **exportar a CSV**.

Para qué lo necesitas:

- Para responder si un cliente pregunta quién ha entrado en su cuenta (tiene derecho a saberlo).
- Para supervisar a tu equipo.
- Para demostrar ante la Agencia Española de Protección de Datos que controlas los accesos.

La columna **Bloqueos** cuenta los intentos que el modo de solo lectura frenó. La columna **Modo** avisa en rojo de las sesiones con acceso completo.

Los accesos más antiguos que el plazo configurado se borran solos. También hay un botón para purgarlos a mano.

---

## 7. Preguntas frecuentes

---

**¿Se ve la contraseña del cliente?** No, en ningún momento. El módulo no la lee, no la descifra y no la cambia.

**¿Se entera el cliente?** Sí, si dejas activado el aviso por correo. Recibe un mensaje con la fecha, quién entró y el motivo. Es lo recomendable.

**¿Puedo hacerle un pedido al cliente?** Solo si desactivas el modo de solo lectura al abrir la sesión. Piénsalo dos veces: queda anotado como acceso completo y el cliente lo verá así en el correo.

**¿Se cierra mi sesión de administrador?** No. El back-office y el front usan cookies distintas: puedes trabajar en las dos pestañas a la vez.

**¿Y si cierro la pestaña sin pulsar «Cerrar la sesión»?** La sesión de soporte caduca sola al cumplirse la duración máxima y queda anotada como caducada. Aun así, es mejor cerrarla a mano.

**¿Funciona con clientes invitados?** No. Las cuentas de invitado no tienen sesión. Tampoco funciona con cuentas desactivadas o borradas.

**¿Puedo usarlo para mirar cuentas por curiosidad?** No. Es un tratamiento de datos personales; hacerlo sin motivo es una infracción y queda registrado con tu nombre.

# ecom\_connectclient — Documentación técnica

**Módulo:** Conectar como cliente **Versión:** 1.0.0 **Autor:** Ecom Experts (ecomyseo@gmail.com) **Licencia:** AFL-3.0 **Compatibilidad declarada:** PrestaShop 1.7.6 → 9.x. **Probado en 8.2.7.** **Arquitectura:** legacy (sin `src/`, sin `config/services.yml`, sin Composer, sin `vendor/`).

## 1. Qué hace

Permite que un empleado autorizado del back-office abra el front de la tienda con la sesión de una cuenta de cliente, para reproducir una incidencia, revisar un pedido o atenderle. El acceso queda anotado íntegramente en un registro de auditoría y está sometido a las garantías que exige el RGPD (ver `DOC-legal-rgpd.md`).

**Lo que NO hace:** no lee, no descifra, no muestra ni cambia la contraseña del cliente. No envía nada a terceros. No recorre el histórico: solo actúa cuando un empleado pulsa el botón.

## 2. Estructura de ficheros

|                                            |                                                      |
|--------------------------------------------|------------------------------------------------------|
| ecom_connectclient/                        |                                                      |
| ecom_connectclient.php                     | clase Ecom_Connectclient (espacio de nombres global) |
| logo.png                                   |                                                      |
| index.php                                  | en TODAS las carpetas, recursivo                     |
| classes/                                   |                                                      |
| EcomConnectClientLog.php                   | registro de accesos (auditoría)                      |
| EcomConnectClientTicket.php                | tickets de un solo uso                               |
| EcomConnectClientLegal.php                 | textos y bases de licitud                            |
| EcomConnectClientLogger.php                | registro de depuración (/logs)                       |
| controllers/                               |                                                      |
| admin/AdminEcomConnectClientController.php |                                                      |
| front/connect.php                          | canjea el ticket y abre la sesión                    |
| front/endsession.php                       | cierra la sesión de soporte                          |
| views/                                     |                                                      |
| css/admin.css, css/front.css               |                                                      |
| js/admin.js, js/front.js                   |                                                      |
| templates/admin/customer_panel.tpl         | panel en la ficha del cliente                        |
| templates/admin/legal.tpl                  | información legal                                    |
| templates/admin/log.tpl                    | registro de accesos completo                         |
| templates/admin/log_summary.tpl            | últimos accesos en la configuración                  |
| templates/admin/gmartos_update.tpl         |                                                      |
| templates/front/ended.tpl                  |                                                      |
| mails/es/, mails/en/                       | aviso al cliente (.html y .txt)                      |
| translations/es-ES/                        | ModulesEcomconnectclientAdmin Shop.es-ES.xlf         |
| sql/install.php                            | consultas de creación de tablas                      |
| logs/                                      | con .htaccess e index.php                            |

### 3. Base de datos

#### `PREFIX_ecom_ccl_log` — registro de accesos

| Columna                                                                             | Tipo          | Para qué                                                                                                         |
|-------------------------------------------------------------------------------------|---------------|------------------------------------------------------------------------------------------------------------------|
| <code>id_ecom_ccl_log</code>                                                        | int PK        |                                                                                                                  |
| <code>id_employee</code> , <code>employee_name</code> , <code>employee_email</code> | int / varchar | quién accedió (se guarda una copia del nombre y del correo, para que la traza sobreviva al borrado del empleado) |
| <code>id_customer</code> , <code>customer_name</code> , <code>customer_email</code> | int / varchar | a qué cuenta                                                                                                     |
| <code>id_shop</code>                                                                | int           | tienda                                                                                                           |
| <code>reason</code>                                                                 | text          | motivo declarado por el operador                                                                                 |
| <code>legal_basis</code>                                                            | varchar       | <code>contract</code> , <code>legitimate_interest</code> o <code>consent</code>                                  |
| <code>consent_ref</code>                                                            | varchar       | evidencia del consentimiento, si la base es esa                                                                  |
| <code>readonly_mode</code>                                                          | tinyint       | si la sesión fue de solo lectura                                                                                 |
| <code>ip</code> , <code>user_agent</code>                                           | varchar       | desde dónde                                                                                                      |
| <code>status</code>                                                                 | varchar       | <code>pending</code> , <code>active</code> , <code>closed</code> , <code>cancelled</code>                        |
| <code>blocked_actions</code>                                                        | int           | intentos bloqueados por el modo de solo lectura                                                                  |
| <code>notified</code>                                                               | tinyint       | si se avisó al cliente por correo                                                                                |
| <code>date_add</code> , <code>date_start</code> , <code>date_end</code>             | datetime      | solicitud, inicio real y cierre                                                                                  |
| <code>end_reason</code>                                                             | varchar       | <code>employee</code> , <code>expired</code> , <code>logout</code> , <code>unknown</code>                        |

Índices: `id_customer` , `id_employee` , `date_add` .

#### `PREFIX_ecom_ccl_ticket` — tickets de un solo uso

`token` (único), `id_ecom_ccl_log` , `id_employee` , `id_customer` , `id_shop` , `readonly_mode` , `used` , `expires_at` , `date_add` .

Vida del ticket: **60 segundos** ( `EcomConnectClientTicket::TTL_SECONDS` ).

## 4. Flujo completo

1. El empleado abre la ficha del cliente en el back-office. El hook `displayAdminCustomers` pinta el panel con el formulario (motivo, solo lectura, casilla de confirmación).
2. El formulario hace `POST` con `target="_blank"` a `AdminEcomConnectClientController`.
3. `processConnect()` valida permisos, perfil, estado de la cuenta, motivo, evidencia del consentimiento y el límite por hora. Llama a `Ecom_Connectclient::startSupportSession()`.
4. `startSupportSession()` **primero** escribe la entrada del registro ( `pending` ) y **después** crea el ticket. Si el registro falla, la sesión no se abre: sin traza no hay acceso.
5. Redirección a `index.php?fc=module&module=ecom_connectclient&controller=connect&t=TOKEN`.
6. El front controller `connect` canjea el ticket ( `UPDATE ... SET used=1 WHERE used=0` , consumo atómico), llama a `Context::updateCustomer()` —que es lo que materializa de verdad la sesión del cliente—, escribe las marcas en la cookie del front, marca el registro como `active` y envía el aviso al cliente. Redirige a la página de destino.
7. Durante toda la sesión, `hookDisplayHeader` inyecta el aviso visible y `hookActionDispatcherBefore` vigila cada petición: caducidad, modo de solo lectura y bloqueo de los cambios de correo y contraseña.
8. El botón «Cerrar la sesión» del aviso lleva al front controller `endsession` , que marca el fin en el registro, limpia la cookie y hace `logout()` del cliente.

**Por qué ticket y no escribir la cookie desde el back-office.** La sesión del front se materializa en una petición normal del front. Un endpoint que hace `exit` , o el propio back-office, no la persisten de forma fiable (en PS 9 directamente no funciona). El patrón ticket → front controller vale en 8.x y en 9.x.

## 5. Hooks registrados

| Hook                                         | Método                                           | Para qué                                                                         |
|----------------------------------------------|--------------------------------------------------|----------------------------------------------------------------------------------|
| <code>displayAdminCustomers</code>           | <code>hookDisplayAdminCustomers</code>           | panel en la ficha del cliente                                                    |
| <code>displayBackOfficeHeader</code>         | <code>hookDisplayBackOfficeHeader</code>         | CSS y JS del back-office                                                         |
| <code>displayHeader</code>                   | <code>hookDisplayHeader</code>                   | aviso visible del front<br>(guardián estático<br><code>\$bannerRendered</code> ) |
| <code>actionDispatcherBefore</code>          | <code>hookActionDispatcherBefore</code>          | caducidad, solo lectura y bloqueos                                               |
| <code>actionCustomerLogoutAfter</code>       | <code>hookActionCustomerLogoutAfter</code>       | cierra el registro si el cliente cierra sesión                                   |
| <code>actionObjectCustomerDeleteAfter</code> | <code>hookActionObjectCustomerDeleteAfter</code> | anonimiza el registro<br>(derecho de supresión)                                  |

## 6. Configuración

Todas las claves son **globales** ( `Configuration::getGlobalValue` / `updateGlobalValue` ): son ajustes de seguridad y deben valer igual en todas las tiendas de la instalación. Cuando el multitienda está activo se avisa en la propia pantalla.

| Clave                                  | Por defecto         | Qué controla                                     |
|----------------------------------------|---------------------|--------------------------------------------------|
| <code>ECOM_CCL_ENABLED</code>          | 1                   | activa la funcionalidad                          |
| <code>ECOM_CCL_PROFILES</code>         | 1 (SuperAdmin)      | perfiles autorizados, separados por comas        |
| <code>ECOM_CCL_MAX_MINUTES</code>      | 30                  | duración máxima de la sesión                     |
| <code>ECOM_CCL_MAX_PER_HOUR</code>     | 10                  | conexiones por empleado y hora                   |
| <code>ECOM_CCL_READONLY</code>         | 1                   | modo de solo lectura por defecto                 |
| <code>ECOM_CCL_BLOCK_IDENTITY</code>   | 1                   | bloquea siempre el cambio de correo y contraseña |
| <code>ECOM_CCL_REQUIRE_REASON</code>   | 1                   | exige motivo                                     |
| <code>ECOM_CCL_MIN_REASON_LEN</code>   | 15                  | longitud mínima del motivo                       |
| <code>ECOM_CCL_LEGAL_BASIS</code>      | contract            | base de licitud del artículo 6.1 del RGPD        |
| <code>ECOM_CCL_NOTIFY_CUSTOMER</code>  | 1                   | avisa al cliente por correo                      |
| <code>ECOM_CCL_NOTIFY_COPY</code>      | vacío               | copia interna del aviso                          |
| <code>ECOM_CCL_BANNER</code>           | 1                   | aviso visible en el front                        |
| <code>ECOM_CCL_LOG_RETENTION</code>    | 12                  | meses de conservación del registro               |
| <code>ECOM_CCL_LANDING</code>          | my-account          | página de destino                                |
| <code>ECOM_CCL_CONTROLLER</code>       | nombre de la tienda | responsable del tratamiento                      |
| <code>ECOM_CCL_DPO_EMAIL</code>        | correo de la tienda | contacto de protección de datos                  |
| <code>ECOM_CCL_PRIVACY_TEXT</code>     | cláusula generada   | texto para la política de privacidad             |
| <code>ECOM_CCL_DEBUG</code>            | 0                   | registro de depuración en <code>/logs</code>     |
| <code>ECOM_CCL_LAST_MAINTENANCE</code> | 0                   | marca de la última purga                         |

El formulario de configuración es **un único HelperForm con cuatro pestañas** (General, Acceso y seguridad, Protección de datos, Aviso al cliente) y un solo botón de guardar. Los paneles de información legal y de últimos accesos son plantillas aparte.

## 7. Medidas de seguridad implementadas

- **Ticket de un solo uso** de 32 bytes aleatorios ( `random_bytes` ), codificado en base64url, con caducidad de 60 segundos y consumo atómico.
- **Sin identificadores en la URL:** el enlace del front no lleva el `id_customer`.
- **Control de acceso por perfil** más los permisos de la pestaña del back-office.
- **Límite por empleado y hora** frente a la recolección masiva.
- **Duración máxima** de la sesión, comprobada en el servidor y en el navegador.
- **Modo de solo lectura:** bloquea todos los `POST`, los controladores `order` y `order-opc`, y las mutaciones del carrito y de las direcciones por `GET`.
- **Bloqueo permanente** de las páginas `identity` (en `POST`) y `password`, para que una sesión de soporte no pueda apropiarse de la cuenta.
- **Aviso visible** en el front durante toda la sesión.
- `pSQL()` en todo el SQL manual; los identificadores van casteados a entero.
- **Cabeceras anti-caché** en la respuesta de bloqueo AJAX y en la exportación CSV.
- `/logs` **protegido** con `.htaccess` e `index.php`; los correos se enmascaran.

## 8. Mantenimiento automático

`Ecom_Connectclient::runMaintenance()` se ejecuta como mucho **una vez al día** al abrir la configuración del módulo, y hace tres cosas:

1. borra los tickets de más de una hora,
2. cierra las sesiones que quedaron abiertas más allá del límite,
3. **purga el registro de accesos fuera del plazo de conservación** (artículo 5.1.e del RGPD).

También hay un botón para purgar a mano, tanto en la configuración como en el registro.

## 9. Traducciones

`isUsingNewTranslationSystem()` devuelve `true`. Las cadenas fuente son inglesas y las traducciones castellanas están en:

```
translations/es-ES/ModulesEcomconnectclientAdmin.es-ES.xlf    (185 cadenas)
translations/es-ES/ModulesEcomconnectclientShop.es-ES.xlf    (16 cadenas)
```

Dominios: `Modules.Ecomconnectclient.Admin` y `Modules.Ecomconnectclient.Shop`. En las plantillas se usa **siempre** `{1 s='...' d='Modules.Ecomconnectclient.Admin'}`; nunca `mod=`, que es el sistema antiguo y no lee los `.xlf`.

Las llamadas a `trans()` llevan siempre el dominio como literal o como constante de clase, nunca como variable, para que el extractor las vea.

---

## 10. Depuración

---

Activa «Registro de depuración» en la pestaña General. Se escribe un fichero por día en `logs/ecom_connectclient-AAAA-MM-DD.log` con los eventos de apertura, cierre y bloqueo. Los correos aparecen enmascarados ( `j***@dominio.com` ) y los tokens nunca se escriben. Déjalo desactivado en producción.

# ecom\_connectclient — Notas para desarrollo

Documento para quien tenga que mantener o ampliar el módulo. Lo que aquí se cuenta son las decisiones que no se deducen leyendo el código, y las trampas que ya costaron tiempo.

## 1. Decisiones de diseño y por qué

### 1.1 Ticket de un solo uso, no escritura directa de la cookie

Lo evidente sería que el back-office escribiera `id_customer` y `logged` en la cookie del front. **No se hace, y no debe hacerse.**

- El back-office y el front usan **cookies distintas** (prefijos distintos): desde el back-office no se puede escribir la del front de forma fiable.
- La sesión del cliente se materializa de verdad en un **request normal del front**, que es lo que hace `Context::updateCustomer()` : asocia el cliente, regenera la sesión, recalcula el carrito y registra una `CustomerSession` .
- En PrestaShop 9 el front del cliente se autentica por la **sesión**, no por la cookie antigua: escribirla desde un endpoint que hace `exit` no loguea y deja un bucle de login. El patrón ticket → front controller funciona igual en 8.x y en 9.x.

El ticket es de 32 bytes de `random_bytes` , base64url, caduca en 60 segundos y se consume con `UPDATE ... SET used = 1 WHERE used = 0` comprobando `Affected_Rows() === 1` . Ese patrón **sí** es atómico (bloqueo de fila), a diferencia de `INSERT IGNORE + Affected_Rows` .

### 1.2 Primero el registro, después el ticket

`startSupportSession()` escribe la entrada del registro **antes** de crear el ticket. Si el registro falla, no se abre nada. Un acceso sin traza no vale: la traza es la medida de seguridad, no un adorno.

Si el ticket nunca se canjea, la entrada queda en `pending` y se marca `cancelled` cuando corresponde. Así se distingue «pidió abrir y no llegó a entrar» de «entró».

### 1.3 Bloqueo por `actionDispatcherBefore` , no por hooks de objeto

El control de la sesión (caducidad, solo lectura, bloqueo de identidad) se hace en `actionDispatcherBefore` , que se dispara en `Dispatcher::dispatch()` **después** de resolver el controlador. Como el hook solo recibe `controller_type` , el nombre del controlador se obtiene con `Dispatcher::getInstance()->getController()` , que devuelve el valor ya cacheado.

La alternativa —engancharse a `actionObject*UpdateBefore` — obligaría a lanzar excepciones en mitad de un guardado y dejaría media operación hecha.

Regla del modo de solo lectura: **se bloquea todo POST** , más los controladores `order` y `order-opc` , más las mutaciones del carrito y de direcciones que van por `GET` . Es simple, y lo simple aquí es lo seguro.

## 1.4 Configuración global, no por tienda

Todas las claves usan `Configuration::getGlobalValue` / `updateGlobalValue`. Son ajustes de seguridad: no tiene sentido que una tienda de la instalación permita conectar a perfiles que otra prohíbe. Cuando `Shop::isFeatureActive()` es cierto se avisa en la propia pantalla para que nadie crea que está configurando solo una tienda.

## 1.5 Copia del nombre y del correo en el registro

El registro guarda `employee_name`, `employee_email`, `customer_name` y `customer_email` además de los identificadores. Es duplicación deliberada: si el empleado se da de baja o el cliente se borra, la traza tiene que seguir diciendo quién fue. El derecho de supresión se atiende **anonimizando** esas columnas, no borrando la fila.

## 1.6 Sin `src/`, sin Composer

Estructura legacy pura. La llamada a `modules.gmartos.es` se hace con **cURL nativo**, no con Guzzle, para no depender de `vendor/`.

## 2. Trampas ya pisadas (no repetir las)

- `(array) $x` **no es «un array o vacío»**. `Db::executeS()` devuelve `false` cuando no hay filas, y `(array) false` es `array(0 => false)`: el `foreach` entra una vez con `false` y revienta al leer una clave. En este módulo se usa siempre `is_array($filas) ? $filas : array()`.
- **Cabeceras anti-caché sin `Content-Type: application/json`**. La respuesta de bloqueo AJAX manda las tres cabeceras anti-caché y **no** manda `Content-Type: application/json`: con ella, jQuery entrega la respuesta ya convertida en objeto y el `JSON.parse()` del lado del cliente falla con `"[object Object]" is not valid JSON`.
- `{1 s='...' mod='...'}` **no lee los `.xlf`**. Con `isUsingNewTranslationSystem() === true` hay que usar `d='Modules.Ecomconnectclient.Admin'` en las plantillas y `trans('...', [], 'Modules.Ecomconnectclient.Admin')` en PHP.
- **El dominio de `trans()` nunca en una variable**. Si se escribe `trans('Texto', [], $domain)`, el extractor no ve la cadena y se queda sin traducir sin que nadie se entere. En este módulo el dominio va siempre como literal o como constante de clase (`Ecom_Connectclient::DOMAIN_ADMIN`).
- **La ruta del `.xlf` es media batalla**. En ejecución PrestaShop solo lee `translations/<locale>/Modules<Nombre><Dominio>.<locale>.xlf`. Un fichero monolítico en la raíz de `translations/` solo lo ve el editor del back-office.
- `Tab::getIdFromClassName` **puede lanzar `NonUniqueResult`** con pestañas duplicadas. `installTab()` y `uninstallTab()` consultan la tabla con `Db::getValue` / `executeS`.
- **El JavaScript del front construye el aviso al vuelo**. Se engancha en `DOMContentLoaded` y crea el nodo; el `admin.js` usa **delegación sobre `document`** porque los paneles se pintan después de cargar la página.

### 3. Cómo probar los caminos importantes

| Camino                 | Cómo forzarlo                                                   | Qué tiene que pasar                                                                  |
|------------------------|-----------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Ticket caducado        | Copiar la URL de conexión y esperar 60 s antes de abrirla       | Redirección al inicio con <code>cc1_error=1</code> , entrada en <code>pending</code> |
| Ticket reutilizado     | Abrir dos veces la misma URL                                    | La segunda no abre sesión                                                            |
| Solo lectura           | Conectar con solo lectura y pulsar «Añadir al carrito»          | Bloqueo, aviso y <code>blocked_actions</code> +1                                     |
| Bloqueo de identidad   | Con solo lectura desactivado, guardar en «Información personal» | Bloqueado igualmente                                                                 |
| Caducidad de la sesión | Poner la duración máxima en 1 minuto                            | La sesión se cierra sola y se anota <code>expired</code>                             |
| Límite por hora        | Poner el tope en 1 y conectar dos veces                         | La segunda se rechaza con el mensaje del límite                                      |
| Perfil no autorizado   | Entrar con un empleado de otro perfil                           | El panel muestra el aviso y no deja conectar                                         |
| Supresión              | Borrar la cuenta de un cliente con accesos                      | Sus columnas de nombre y correo quedan vacías en el registro                         |
| Purga                  | Poner la conservación en 1 mes y pulsar purgar                  | Se borran las entradas fuera de plazo                                                |

### 4. Extensiones razonables

- **Acción de fila en el listado de clientes** con `actionCustomerGridDefinitionModifier`. Se descartó en la versión 1.0.0 porque `LinkRowAction` necesita una ruta Symfony y aquí el destino es un controlador admin legacy con `POST`. Si se hace, la vía es un `LinkRowAction` a una ruta propia o un `SubmitRowAction`, nunca inyectando HTML por JavaScript en el listado (el back-office cambia su marcado entre versiones).
- **Aviso al cliente por otros canales** (WhatsApp, SMS): reutilizar `notifyCustomer()` y añadir el canal ahí, no en el front controller.
- **Panel de supervisión** con métricas por empleado a partir de `ecom_cc1_log`.

Cualquier ampliación que toque el registro tiene que respetar dos reglas: **no se abre sesión sin traza** y **no se guarda la traza más allá del plazo de conservación**.

## 5. Convenciones del proyecto que aplican aquí

---

- Cabecera de autoría y licencia en **todos** los ficheros, sin líneas en blanco antes ni después de `<?php`.
- `if (!defined('_PS_VERSION_')) { exit; }` en todos los PHP.
- `index.php` con redirección en **todas** las carpetas, recursivamente.
- Migraciones y altas de hooks en `addnewfeatures()`, dentro de `try {}`, invocada al abrir la configuración.  
**Sin carpeta** `upgrade/`.
- Formulario de configuración: **un solo** `HelperForm` **con pestañas**, nunca varios `fields_form` apilados.
- Escape obligatorio en Smarty ( `|escape:'html':'UTF-8'` ), **prohibido** `nofilter`.
- Nada de `LIMIT 1` a mano: `getRow` y `getValue` ya lo añaden.
- Textos en castellano con tildes y eñes. Las cadenas fuente ( `<source>` , `resname` ) van **siempre en inglés** y no se tocan.

# ecom\_connectclient — Información legal y cumplimiento del RGPD

---

Este documento explica el marco legal que se ha revisado antes de escribir el módulo y cómo cada exigencia se traduce en una función concreta. **No es asesoramiento jurídico.** El responsable del tratamiento sigue siendo el titular de la tienda; haz revisar los textos por tu asesor de protección de datos.

## Normativa aplicable:

- Reglamento (UE) 2016/679, de 27 de abril de 2016, General de Protección de Datos (**RGPD**).
- Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (**LOPDGDD**).
- Criterios de la Agencia Española de Protección de Datos (**AEPD**) sobre control de accesos, trazabilidad y deber de confidencialidad del personal.

---

## 1. Por qué esto es un tratamiento de datos personales

«Conectar como cliente» significa que una persona de la tienda ve la cuenta de otra persona con sus propios ojos: sus pedidos, sus direcciones, sus facturas y su carrito. Eso es un **tratamiento de datos personales** en el sentido del artículo 4.2 del RGPD, y uno especialmente delicado, porque:

- el interesado **no lo espera**: cree que su cuenta solo la ve él;
- **falsea la traza de auditoría** si no se anota: cualquier cambio hecho durante la sesión aparece como si lo hubiera hecho el cliente;
- concentra en una sola acción **todos los datos** de esa persona en la tienda.

No es una cesión a terceros (los datos no salen de la tienda) ni un encargo del tratamiento, salvo que quien opere sea una agencia externa: en ese caso hace falta el contrato del **artículo 28 del RGPD**.

---

## 2. Base de licitud (artículo 6.1 del RGPD)

El módulo obliga a elegir una y la guarda **en cada entrada del registro**, de modo que para cada acceso queda constancia de por qué era lícito.

| Base                                                       | Cuándo vale                                                                                | Qué exige el módulo                                                                                                                                                                           |
|------------------------------------------------------------|--------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Ejecución del contrato</b> (6.1.b) — <i>por defecto</i> | El cliente pide ayuda con un pedido y el acceso es estrictamente necesario para prestarla. | Motivo declarado.                                                                                                                                                                             |
| <b>Interés legítimo</b> (6.1.f)                            | Soporte técnico, investigación de fraude, diagnóstico de incidencias.                      | Motivo declarado <b>y un juicio de ponderación documentado por tu parte</b> : el interesado no espera este acceso, así que hay que justificar que tu interés no prevalece sobre sus derechos. |
| <b>Consentimiento</b> (6.1.a)                              | El cliente lo autoriza expresamente.                                                       | El módulo <b>exige anotar la evidencia</b> (número de ticket, correo, referencia de la llamada) y no deja conectar sin ella.                                                                  |

### 3. Principios del artículo 5 y su traducción en el módulo

| Principio                            | Artículo | Cómo se cumple                                                                                                                                                       |
|--------------------------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Licitud, lealtad y transparencia     | 5.1.a    | Base de licitud configurable, aviso visible en el front, correo al cliente y cláusula lista para la política de privacidad.                                          |
| Limitación de la finalidad           | 5.1.b    | <b>Motivo obligatorio</b> con longitud mínima, guardado en el registro.                                                                                              |
| Minimización de datos                | 5.1.c    | <b>Modo de solo lectura</b> : durante la sesión no se puede pedir, pagar ni cambiar nada. Duración máxima de la sesión.                                              |
| Exactitud                            | 5.1.d    | El registro guarda una copia del nombre y del correo del empleado y del cliente en el momento del acceso, para que la traza no dependa de datos que cambien después. |
| Limitación del plazo de conservación | 5.1.e    | <b>Purga automática</b> del registro según el plazo configurado (12 meses por defecto).                                                                              |
| Integridad y confidencialidad        | 5.1.f    | Perfiles autorizados, tickets de un solo uso de 60 segundos, límite por hora, sin identificadores en la URL, <code>/logs</code> protegido.                           |
| Responsabilidad proactiva            | 5.2 y 24 | El <b>registro de accesos</b> exportable a CSV es la evidencia con la que demostrar el cumplimiento.                                                                 |

### 4. Seguridad del tratamiento (artículo 32 del RGPD)

El artículo 32 exige medidas técnicas y organizativas adecuadas al riesgo. Las que trae el módulo:

- **Control de acceso por perfil** ( `ECOM_CCL_PROFILES` ), además de los permisos de la pestaña del back-office.
- **Autenticación sin credenciales robadas**: no se lee ni se descifra la contraseña; el acceso se concede con un ticket de un solo uso que caduca en 60 segundos y que se consume de forma atómica.
- **Trazabilidad**: quién, cuándo, a quién, desde qué IP, con qué navegador, con qué motivo, con qué base de licitud, cuánto duró y cuántos intentos se bloquearon.
- **Limitación de la superficie**: duración máxima, tope por hora, modo de solo lectura y bloqueo permanente del cambio de correo y contraseña.
- **Confidencialidad de los registros**: `/logs` con `.htaccess` , correos enmascarados en el registro de depuración y en el resumen de la configuración.

## 5. Transparencia (artículos 12 a 14)

Tres capas, y las tres están implementadas:

1. **Información previa y general**. El módulo genera una cláusula lista para copiar en la política de privacidad. Está en la pestaña «Protección de datos» y en el panel de información legal.
2. **Aviso en el momento**. Correo automático al cliente con la fecha, quién accedió, el motivo y el tipo de acceso. Se puede desactivar, pero mantenerlo es lo más seguro.
3. **Aviso visible durante el acceso**. Una barra fija en el front que no deja lugar a dudas y que impide que el acceso pase por navegación del propio cliente. Desactivarla convierte el acceso en oculto y va contra el principio de transparencia.

## 6. Derechos del interesado (artículos 15 a 22)

| Derecho                   | Cómo se atiende                                                                                                                                                                                                      |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Acceso</b> (15)        | Exportación CSV del registro filtrado por cliente, desde el registro de accesos.                                                                                                                                     |
| <b>Rectificación</b> (16) | No aplica al registro: es una traza de hechos.                                                                                                                                                                       |
| <b>Supresión</b> (17)     | Al borrar la cuenta del cliente, el hook <code>actionObjectCustomerDeleteAfter</code> <b>anonimiza</b> su nombre y su correo en el registro y conserva solo la traza técnica que exige la responsabilidad proactiva. |
| <b>Oposición</b> (21)     | Si te apoyas en el interés legítimo, el cliente puede oponerse. Anota la oposición y no vuelvas a conectar a esa cuenta. El módulo no lo automatiza: es una decisión organizativa.                                   |

## 7. Obligaciones que siguen siendo tuyas

1. **Registro de actividades de tratamiento (artículo 30).** Anota este tratamiento: finalidad («soporte al cliente mediante acceso a su cuenta»), categorías de datos, destinatarios, plazo de conservación y medidas de seguridad.
2. **Deber de confidencialidad del personal** (artículo 5 de la LOPDGDD y artículo 29 del RGPD). El módulo obliga al operador a marcar una casilla reconociéndolo en cada acceso, pero eso no sustituye al compromiso firmado.
3. **Contrato de encargo (artículo 28)** si quien opera la tienda es una agencia externa.
4. **Evaluación de impacto (artículo 35)** si el acceso a cuentas de clientes es sistemático y a gran escala.
5. **Violaciones de seguridad (artículos 33 y 34).** Un uso indebido de esta funcionalidad —un empleado curioseando cuentas— es una violación de seguridad de los datos personales y puede haber que notificarla en 72 horas. El registro de accesos es justo lo que permite detectarlo y acotarlo.
6. **Juicio de ponderación** documentado si eliges el interés legítimo como base.
7. **Mínimo de perfiles autorizados.** Por defecto solo el SuperAdmin. Cada perfil que añadas amplía el número de personas que pueden ver cuentas ajenas.

## 8. Recomendaciones de configuración

| Ajuste                                 | Recomendado   | Por qué                                                            |
|----------------------------------------|---------------|--------------------------------------------------------------------|
| Perfiles autorizados                   | Los mínimos   | Es el control de acceso del artículo 32.                           |
| Modo de solo lectura                   | Activado      | Minimización: casi todas las incidencias se diagnostican mirando.  |
| Bloquear cambio de correo y contraseña | Activado      | Impide que una sesión de soporte se apropie de la cuenta.          |
| Duración máxima                        | 15–30 minutos | Cuanto más corta, menor exposición.                                |
| Conexiones por hora                    | 5–10          | Corta la recolección masiva.                                       |
| Aviso al cliente                       | Activado      | Transparencia real, y desactiva la sospecha antes de que aparezca. |
| Aviso visible                          | Activado      | Evita que el acceso quede oculto.                                  |
| Conservación del registro              | 12 meses      | Suficiente para investigar y acorde con la limitación del plazo.   |

## 9. Fuentes

---

- Reglamento (UE) 2016/679 (RGPD) — <https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX%3A32016R0679>
- Ley Orgánica 3/2018 (LOPDGDD) — <https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673>
- Agencia Española de Protección de Datos — <https://www.aepd.es/>